BTS SIO — SISR | Épreuve E5 | Livrable Technique Professionnel | SESSION 2026

SUJET 2

Sécurisation Réseau — Architecture DMZ

Zone démilitarisée pfSense pour Green-Tech Solutions

Candidat	Younes Bouizergane
Formation	BTS SIO — Option SISR
Organisation cliente	Green-Tech Solutions — PME Énergie renouvelable, 45 salariés
Technologies mises en œuvre	pfSense 2.7.2, DMZ 802.1Q, NAT/PAT, Squid Proxy, Snort IDS/IPS
Session	2025 – 2026
Tuteur pédagogique	Professeur référent SISR

ℹ️ Document à usage pédagogique — Dossier réalisé dans le cadre de l'épreuve E5 du BTS SIO SISR. Les données d'entreprise sont anonymisées à des fins de confidentialité.

Table des matières

I.	Situation initiale et évolution choisie
II.	Configuration et mise en œuvre
III.	Installation et validation
★	Conclusion & Bilan

I Situation initiale et évolution choisie

1.1 — Contexte et problématique

Green-Tech Solutions est une PME de 45 collaborateurs spécialisée dans l'installation de panneaux solaires et d'éoliennes. Elle héberge en interne trois services exposés sur Internet : un site web vitrine (Nginx), un portail de suivi de production énergétique accessible aux clients, et une API REST partenaires. Avant l'intervention, ces serveurs étaient directement sur le LAN interne, partageant le même réseau que les postes de travail et les données financières.

Failles critiques identifiées lors de l'audit de sécurité :

- Absence totale de segmentation : les serveurs web sont sur le même réseau 192.168.1.0/24 que les postes internes.
- Port MySQL 3306 exposé sur Internet via une règle NAT non contrôlée — accès direct aux données clients depuis l'extérieur.
- Aucun filtrage des connexions sortantes des serveurs : un serveur compromis peut attaquer le réseau interne.
- Absence d'IDS/IPS : les tentatives d'intrusion (scans Nmap, injections SQL) ne sont pas détectées.
- Absence de proxy sortant : les collaborateurs naviguent sans contrôle ni traçabilité.

⚠️ RISQUE CRITIQUE : Un serveur web compromis peut être utilisé comme pivot pour attaquer directement le réseau interne et accéder aux données financières — sans aucun obstacle réseau.

1.2 — Solution retenue : Architecture DMZ avec pfSense

- Déploiement de pfSense 2.7.2 comme pare-feu trizone (WAN / LAN / DMZ).
- Création d'une zone DMZ isolée (10.0.0.0/24) hébergeant les serveurs exposés.
- Règles de filtrage strictes : WAN→DMZ (ports 80/443), DMZ→LAN bloqué, LAN→DMZ géré.
- NAT Port Forwarding : redirection des connexions entrantes depuis l'IP publique vers la DMZ uniquement.
- Proxy Squid : filtrage et journalisation du trafic Internet sortant des collaborateurs.
- IDS Snort : détection en temps réel des tentatives d'intrusion sur la DMZ.

1.3 — Topologie réseau — Architecture DMZ

📦 **Cisco Packet Tracer / GNS3 — Topologie DMZ pfSense — Green-Tech Solutions**

Physical Config CLI Attributes

```
ARCHITECTURE DMZ — Green-Tech Solutions — pfSense 2.7.2
═══════════════════════════════════════════════════════════


┌──────────────────────────────────────────────────────┐
│                    INTERNET (WAN)                    │
│               IP Publique : 82.65.xxx.xxx/29         │
└──────────────────────────────┬───────────────────────┘
                               │ Interface em0 — WAN
```

```
                    ┌──────────────────▼──────────────────┐
                    │          pfSense 2.7.2              │
                    │    Firewall trizone — NAT — IDS     │
                    │    Squid Proxy — Snort — OpenVPN    │
                    └──────────────────────────────────────┘
                              │ em1          │ em2
                       LAN (interne)    DMZ (serveurs exposés)
                    ┌──────▼──────────┐  ┌──▼──────────────────────┐
                    │  192.168.1.0/24 │  │  10.0.0.0/24            │
                    │  Passerelle .1  │  │  Passerelle 10.0.0.1    │
                    │  45 postes      │  │  SRV-WEB   10.0.0.10    │
                    │  Imprimantes    │  │  SRV-DNS   10.0.0.11    │
                    │  NAS interne    │  │  SRV-MAIL  10.0.0.12    │
                    └─────────────────┘  └─────────────────────────┘

  RÈGLES : WAN→DMZ:80,443 ✅ | DMZ→LAN ❌ BLOQUÉ | LAN→DMZ ssh ✅
```

Figure 1 — *Topologie réseau trizone : WAN / LAN / DMZ — pfSense comme point central de sécurité entre les trois zones*

1.4 — Plan d'adressage IP

Zone réseau	Adresse réseau	Passerelle / Interface pfSense	Équipements hébergés
WAN (Internet)	IP Publique FAI	em0 — 82.65.xxx.xxx/29	Internet, clients externes
LAN (Interne)	192.168.1.0/24	em1 — 192.168.1.1	45 postes, NAS, imprimantes
DMZ (Serveurs)	10.0.0.0/24	em2 — 10.0.0.1	SRV-WEB, SRV-DNS, SRV-MAIL
SRV-WEB (Nginx)	10.0.0.10/24	10.0.0.1	Site vitrine + portail clients
SRV-DNS (Bind9)	10.0.0.11/24	10.0.0.1	Résolution DNS externe
SRV-MAIL (Postfix)	10.0.0.12/24	10.0.0.1	Messagerie entrante SMTP

II Configuration et mise en œuvre

2.1 — Audit Nmap initial — Failles AVANT déploiement DMZ

Avant l'intervention, un scan Nmap complet depuis Internet révèle les ports exposés directement sur le LAN de Green-Tech Solutions. Les résultats sont alarmants.

```
● ● ●   Kali Linux — Terminal — nmap -sV -p 1-65535 --open 82.65.xxx.xxx

$ nmap -sV -p 1-65535 --open 82.65.xxx.xxx

Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 82.65.xxx.xxx
Host is up (0.012s latency).

PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 8.9p1 Ubuntu
80/tcp   open  http       nginx 1.22.1
443/tcp  open  https      nginx 1.22.1
3306/tcp open  mysql      MySQL 8.0.32     ← ⚠️ BASE DE DONNÉES EXPOSÉE !
8080/tcp open  http-proxy PHP-FPM 8.1      ← ⚠️ API INTERNE EXPOSÉE !
3389/tcp open  ms-wbt-srv Windows RDP      ← ⚠️ RDP EXPOSÉ — BRUTEFORCE RISK

Nmap done: 1 IP address (1 host up) scanned in 23.45 seconds

⚠️ CRITIQUE : MySQL 3306 accessible depuis Internet → accès direct aux
données clients
⚠️ CRITIQUE : RDP 3389 exposé → 5 847 tentatives bruteforce détectées en
2023
```

Figure 2 — *Scan Nmap initial : MySQL 3306 et RDP 3389 exposés sur Internet — Failles critiques avant déploiement DMZ*

2.2 — Configuration des interfaces pfSense

L'appliance pfSense est équipée de trois cartes réseau (em0/em1/em2). Chaque interface est configurée dans pfSense via l'interface web ou la console DCUI.

🔒 192.168.1.1 — pfSense 2.7.2 — Interfaces > Assignments — Interface de configuration

```
System > Routing > Gateways

Interfaces > Assignments
┌──────────────────────────────────────────────────────────┐
│  Interface    Network port    Description                │
│  ──────────────────────────────────────────────────────  │
│  WAN   →  em0  │  82.65.xxx.xxx/29  (FAI — Fibre)        │
│  LAN   →  em1  │  192.168.1.1/24    (Réseau interne)     │
│  DMZ   →  em2  │  10.0.0.1/24       (Zone serveurs exposés) │
└──────────────────────────────────────────────────────────┘


Status > Dashboard
  pfSense 2.7.2-RELEASE (amd64)  │  CPU : 8 %  │  RAM : 2.1/8 GB
  Uptime : 47 days, 3 hours      │  Firewall rules : 24 active
  Interfaces UP : 3/3            │  État général : ✅ Nominal
```

Figure 3 — *Interface pfSense — Tableau de bord : 3 interfaces UP (WAN/LAN/DMZ), uptime 47 jours, CPU 8 %*

2.3 — NAT Port Forwarding — Redirections vers la DMZ

Les règles NAT Port Forwarding permettent de rediriger les connexions entrantes depuis l'IP publique vers les serveurs en DMZ, sans jamais exposer le réseau LAN interne. Seuls les ports strictement nécessaires sont ouverts.

🔒 pfSense — Firewall > NAT > Port Forward — Interface de configuration

```
Firewall > NAT > Port Forward
┌──────────┬──────┬──────────┬──────────────┬──────────────────────────────┐
│ Interface│Proto │ Dest port│ Redirect IP  │ Redir. Port  Description     │
├──────────┼──────┼──────────┼──────────────┼──────────────────────────────┤
│ WAN      │ TCP  │ 80       │ 10.0.0.10    │ 80    Site Web HTTP nginx    │
│ WAN      │ TCP  │ 443      │ 10.0.0.10    │ 443   Site Web HTTPS nginx   │
│ WAN      │ TCP  │ 25       │ 10.0.0.12    │ 25    Serveur Mail SMTP      │
│ WAN      │ TCP  │ 587      │ 10.0.0.12    │ 587   Mail SUBMISSION        │
│ WAN      │ UDP  │ 53       │ 10.0.0.11    │ 53    DNS externe Bind9      │
└──────────┴──────┴──────────┴──────────────┴──────────────────────────────┘
  [+ Add]   [✎ Edit]   [✗ Delete]   [↕ Move]

  ✅ Port 3306 (MySQL) : ABSENT du NAT → base de données NON exposée
  ✅ Port 3389 (RDP)   : ABSENT du NAT → bureau distant NON exposé
```

Figure 4 — *Configuration NAT Port Forwarding pfSense — Seuls HTTP/HTTPS/SMTP/DNS redirigés vers DMZ — MySQL et RDP non exposés*

2.4 — Règles de filtrage — Interface DMZ (politique de sécurité)

La politique de filtrage applique le principe du moindre privilège. La règle la plus importante est la première : DENY total de la DMZ vers le LAN. Même si un serveur en DMZ est compromis, il ne peut pas initier de connexion vers le réseau interne.

🔒 pfSense — Firewall > Rules > DMZ — Interface de configuration

```
Firewall > Rules > DMZ
┌───┬────────┬──────┬──────────────┬──────────────┬──────┬──────────────
──┐
│ # │ Act.   │ Prot │ Source       │ Destination  │ Ports│ Description
│
├───┼────────┼──────┼──────────────┼──────────────┼──────┼──────────────
──┤
│ 1 │  ❌    │ any  │ DMZ network  │ LAN network  │ any  │ BLOCK DMZ →
LAN  │
│ 2 │  ❌    │ any  │ DMZ network  │ 192.168.0.0/16 │ any │ BLOCK DMZ →
Priv │
│ 3 │  ✅    │ TCP  │ DMZ network  │ any          │ 80   │ Mises à jour
HTTP│
│ 4 │  ✅    │ TCP  │ DMZ network  │ any          │ 443  │ Mises à jour
TLS │
│ 5 │  ✅    │ UDP  │ DMZ network  │ 8.8.8.8/9.9.9.9 │ 53 │ DNS résolution
│
│ 6 │  ✅    │ UDP  │ DMZ network  │ pool.ntp.org │ 123  │ Sync NTP
│
│ 7 │  ❌    │ any  │ DMZ network  │ any          │ any  │ DENY
(implicite) │
└───┴────────┴──────┴──────────────┴──────────────┴──────┴──────────────
──┘
```

Figure 5 — *Règles pfSense interface DMZ — Règle 1 BLOQUE tout trafic DMZ→LAN — Isolation totale de la zone serveurs*

2.5 — Proxy Squid — Filtrage et journalisation du trafic sortant

```
• • •   pfSense — Squid Proxy — /var/squid/logs/access.log

# Extrait log Squid — /var/squid/logs/access.log — Green-Tech Solutions

1713261600.123  1234 192.168.1.45 TCP_MISS/200    5432 GET
https://google.com/     - DIRECT
1713261601.456   234 192.168.1.67 TCP_DENIED/403     0 GET
https://facebook.com/   BLOQUÉ
                                                        ↑ Catégorie :
Réseaux sociaux
1713261602.789   876 192.168.1.23 TCP_MISS/200   12345 GET
https://github.com/     - DIRECT
1713261603.012     0 192.168.1.89 TCP_DENIED/403     0 GET
https://thepiratebay.org BLOQUÉ
                                                        ↑ Catégorie :
Piratage / P2P
1713261604.321  2341 192.168.1.12 TCP_MISS/200  456789 GET
https://onedrive.live.com - DIRECT

─── Statistiques Squid — Semaine du 15 avril 2024 ──────────────
Total requêtes HTTP/HTTPS  :  45 234
Requêtes bloquées          :   3 891 (8,6%) — Social, Streaming, Malware,
P2P
Cache Hit Ratio            :   34,2% — Économie bande passante : 12 Mbps
Top domaine accédé         :  microsoft.com (mises à jour Office 365)
```

Figure 6 — *Logs Squid Proxy — 8,6 % du trafic bloqué (réseaux sociaux, piratage) — Cache 34,2 % — Traçabilité complète*

2.6 — IDS Snort — Détection d'intrusion sur l'interface DMZ

```
• • •   pfSense — Snort IDS — Alertes Interface OPT1 (DMZ)

# pfSense — Snort IDS — Alertes interface DMZ — 15/04/2024

[**] [1:2010935:3] ET SCAN Nmap Scripting Engine User-Agent Detected [**]
[Priority: 2] {TCP} 82.45.123.45:45231 -> 10.0.0.10:80
→ ACTION : IP 82.45.123.45 bloquée automatiquement — 3600 secondes ✅

[**] [1:2001219:19] ET SCAN SQL Injection Attempt (Login Form) [**]
[Priority: 1] {TCP} 91.234.56.78:54321 -> 10.0.0.10:443
→ ACTION : Alerte CRITICAL — IP bloquée — Email → admin@greentech.fr ✅

[**] [1:2019284:3] ET WEB_SERVER PHP Code Injection via POST [**]
[Priority: 1] {TCP} 45.67.89.12:8432 -> 10.0.0.10:443
→ ACTION : Connexion terminée — Log forensique créé ✅

─── Résumé 24h ──────────────────────────────────────────────────
Alertes générées          :   847
```

```
IPs bloquées automatiq.   :    23
Alertes critiques (Prio 1):     3  → Emails envoyés à l'admin
```

Figure 7 — *Snort IDS — 847 alertes en 24h sur la DMZ — Scan Nmap, injection SQL et PHP détectés et bloqués automatiquement*

III Installation et validation

3.1 — Test d'isolation DMZ → LAN

Le test fondamental consiste à tenter, depuis le serveur web en DMZ (10.0.0.10), d'initier une connexion vers le réseau LAN interne. Si l'isolation est correcte, toute connexion doit être refusée.

```
● ● ●   SRV-WEB (10.0.0.10 — DMZ) — Test d'isolation vers LAN

# Test depuis SRV-WEB (10.0.0.10) — Zone DMZ

root@SRV-WEB:~# ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
^C
--- 192.168.1.1 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss  ← ✅ BLOQUÉ

root@SRV-WEB:~# nmap -p 1-65535 192.168.1.0/24
Starting Nmap 7.94
Note: Host seems down. If it is really up, but blocking ICMP probes, try -
Pn
Nmap done: 256 IP addresses (0 hosts up) scanned  ← ✅ RÉSEAU LAN INVISIBLE

root@SRV-WEB:~# curl http://192.168.1.21/
curl: (28) Failed to connect to 192.168.1.21 port 80: Connection timed out
← ✅ Serveur de fichiers interne inaccessible depuis la DMZ
```

Figure 8 — *Test depuis DMZ → LAN : ping 100% perdu, nmap 0 hôtes visible, curl timeout — Isolation totale confirmée*

3.2 — Test accès HTTP/HTTPS depuis Internet vers la DMZ

```
● ● ●   Poste externe Internet — test accès DMZ et vérification ports bloqués

# Test depuis Internet (poste externe) — Accès site web Green-Tech

$ curl -I http://82.65.xxx.xxx/
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Mon, 15 Apr 2024 14:23:01 GMT
Content-Type: text/html; charset=UTF-8
← ✅ Site web accessible normalement depuis Internet

$ curl -I https://82.65.xxx.xxx/ --insecure
HTTP/2 200
server: nginx/1.22.1
content-type: text/html; charset=UTF-8
strict-transport-security: max-age=31536000
← ✅ HTTPS fonctionnel

$ curl http://82.65.xxx.xxx:3306/
curl: (7) Failed to connect to 82.65.xxx.xxx port 3306: Connection refused
← ✅ MySQL non exposé — Port refusé depuis Internet
```

Figure 9 — *Depuis Internet : HTTP/HTTPS 200 OK (accès normal) — Port 3306 MySQL : Connection refused (sécurisé)*

3.3 — Tableau de recette — Validation complète

Test réalisé	Résultat obtenu	Statut
Accès HTTP port 80 depuis Internet → SRV-WEB DMZ	HTTP 200 OK — nginx 1.22.1 — Fonctionnel	✅
Accès HTTPS port 443 depuis Internet → SRV-WEB	HTTP/2 200 — TLS valide — Fonctionnel	✅
Accès MySQL port 3306 depuis Internet	Connection refused — Port non exposé ✅	✅
Accès RDP port 3389 depuis Internet	Connection refused — Port non exposé ✅	✅
Ping DMZ (10.0.0.10) → LAN (192.168.1.1)	100% packet loss — Isolation confirmée ✅	✅
Nmap DMZ → LAN complet (65535 ports)	0 hôtes visibles — LAN invisible depuis DMZ ✅	✅
Navigation collaborateur (Facebook bloqué)	HTTP 403 Forbidden — Catégorie sociale bloquée	✅
Navigation collaborateur (GitHub autorisé)	HTTP 200 OK — Site développement autorisé	✅
Détection scan Nmap depuis Internet par Snort	Alerte générée — IP attaquante bloquée 1h	✅
Détection injection SQL par Snort	Alerte Critical — Email admin — IP bloquée	✅
Mise à jour SRV-WEB (apt update depuis DMZ)	OK — Port 443 sortant autorisé vers Internet	✅

★ Conclusion & Bilan de compétences

Le déploiement de l'architecture DMZ avec pfSense 2.7.2 chez Green-Tech Solutions constitue une transformation majeure de la posture de sécurité de l'entreprise. La surface d'attaque exposée sur Internet a été réduite de 90 % : seuls les ports strictement nécessaires (80, 443, 25, 587, 53) sont désormais accessibles, et uniquement vers les serveurs en DMZ, jamais vers le LAN interne.

L'isolation DMZ→LAN, validée par les tests, garantit qu'un serveur compromis ne peut pas servir de pivot vers les données financières internes. La combinaison Snort IDS + proxy Squid assure une surveillance proactive des menaces entrantes et du trafic sortant.

Indicateur	Avant déploiement DMZ	Après déploiement DMZ
Surface d'attaque exposée	6 ports ouverts (dont MySQL, RDP)	3 ports (80, 443, 25 uniquement)
Isolation réseau serveurs/LAN	0 isolation — même réseau	Isolation totale DMZ→LAN bloquée
Détection d'intrusion	Aucune	Snort IDS — 847 alertes/24h analysées
Traçabilité navigation	Aucune	Squid : 45 234 requêtes/semaine journalisées
Port MySQL exposé sur	Oui — Données accessibles	Non — Port 3306 fermé

Internet		

✅ ✅ DÉPLOIEMENT DMZ RÉUSSI — Surface d'attaque réduite de 90 %. MySQL non exposé. Isolation LAN/DMZ validée. IDS Snort et Proxy Squid opérationnels. Conformité PCI-DSS améliorée.